

Security Audit Report

Milestone 2

SecureCart Inc.

Team

Daniel Pereira – 2021237092

Diogo Larangeira – 2025195644

Inês Tovar – 2022225151

Rodrigo Rodrigues – 2022233032

Security Audit

Coimbra, April 2026

Contents

1	Introduction	4
2	Methodology	4
3	Executive Summary	5
4	Detailed Findings	7
4.1	Organizational Controls	7
4.1.1	A.5.1 — Policies for Information Security	7
4.1.2	A.5.2 — Information Security Roles and Responsibilities	8
4.1.3	A.5.4 — Management Responsibilities	8
4.1.4	A.5.7 — Threat Intelligence	9
4.1.5	A.5.9 — Inventory of Information and Other Associated Assets	9
4.1.6	A.5.10 — Acceptable Use of Information and Other Associated Assets	10
4.1.7	A.5.12 — Classification of Information	11
4.1.8	A.5.13 — Labeling of Information	11
4.1.9	A.5.14 — Information Transfer	12
4.1.10	A.5.15 — Access Control	12
4.1.11	A.5.16 — Identity Management	13
4.1.12	A.5.17 — Authentication Information	14
4.1.13	A.5.18 — Access Rights	14
4.1.14	A.5.19 — Information Security in Supplier Relationships	15
4.1.15	A.5.20 — Addressing Information Security Within Supplier Agreements . . .	15
4.1.16	A.5.21 — Managing Information Security in the ICT Supply Chain	16

4.1.17	A.5.22 — Monitoring, Review, and Change Management of Supplier Services	17
4.1.18	A.5.23 — Information Security for Use of Cloud Services	18
4.1.19	A.5.24 — Information Security Incident Management Planning and Preparation	18
4.1.20	A.5.25 — Assessment and Decision on Information Security Events	19
4.1.21	A.5.26 — Response to Information Security Incidents	20
4.1.22	A.5.27 — Learning from Information Security Incidents	21
4.1.23	A.5.34 — Privacy and Protection of PII	21
4.2	People Controls	22
4.2.1	A.6.3 — Information Security Awareness, Education, and Training	22
4.2.2	A.6.7 — Remote Working	23
4.3	Technological Controls	24
4.3.1	A.8.1 — User Endpoint Devices	24
4.3.2	A.8.2 — Privileged Access Rights	25
4.3.3	A.8.3 — Information Access Restriction	25
4.3.4	A.8.5 — Secure Authentication	26
4.3.5	A.8.8 — Management of Technical Vulnerabilities	26
4.3.6	A.8.11 — Data Masking	27
4.3.7	A.8.12 — Data Leakage Prevention	27
4.3.8	A.8.13 — Information Backup	28
4.3.9	A.8.15 — Logging	28
4.3.10	A.8.16 — Monitoring Activities	29
4.3.11	A.8.24 — Use of Cryptography	30
5	Audit Summary & Analysis	31
5.1	Compliance Distribution and Maturity Assessment	31

5.2	Gap Severity and Root Cause Analysis	32
5.2.1	The "Scale-Up" Access Control Breakdown	32
5.2.2	E-commerce Data Exposure and Regulatory Risk	32
5.2.3	The Supply Chain and Cloud Blind Spot	33
5.3	Conclusion of the Current State	33
6	Audit Conclusions	34
6.1	Overall Audit Opinion	34
6.2	Conditions for Certification	34
6.3	Follow-Up Audit	34
6.4	Closing Statement	35

1 Introduction

This report presents the findings of the security audit conducted by our team for **SecureCart Inc.**, as external security auditors engaged to assess the organization's compliance with the **ISO/IEC 27001:2022** standard.

The audit was conducted in accordance with the audit plan defined in Milestone 1, covering the key information security domains identified as applicable to SecureCart's operational context: **governance, access control and identity management, asset management, operational security and incident management, third-party and supply chain risk, and privacy and data protection.**

This document presents the simulated audit execution, the evidence collected, the identified compliance gaps, and the corresponding recommendations, mapped to 36 applicable ISO/IEC 27001:2022 controls spanning the Organizational (A.5), People (A.6), and Technological (A.8) control domains.

2 Methodology

The audit followed a risk-based approach aligned with the ISO/IEC 27001:2022 requirements and the controls defined in the Statement of Applicability (SoA) established during Milestone 1.

Audit techniques applied:

- **Document review:** analysis of SecureCart's information security policies, access control procedures, asset inventory, supplier contracts, incident response plan, and operational practices as described in the scenario.
- **Interviews (simulated):** structured interviews with representatives from IT, Operations, HR, Customer Support, Finance, and Security/Compliance.
- **Process walkthroughs:** observation of key processes including user provisioning and de-provisioning, incident escalation, alert handling, and supplier management.

Gap classification model:

- **Critical:** control absence or failure with immediate high risk to confidentiality, integrity, or availability.
- **Major:** significant control weakness or inconsistent implementation that materially increases security risk.
- **Minor:** localized or procedural weakness with limited impact, still requiring planned correction.

- **Observation:** improvement opportunity where baseline compliance exists but maturity can be strengthened.

Conformity criteria:

- **Conformant:** control requirements are defined, implemented, and evidenced.
- **Partially conformant:** control exists but is incomplete, inconsistent, or weakly evidenced.
- **Nonconformant:** required control is missing, not implemented, or ineffective.

3 Executive Summary

This section presents a high-level overview of the audit findings across the three assessed control domains: Organizational Controls (A.5), People Controls (A.6), and Technological Controls (A.8). The findings reveal a consistent pattern across all domains — while SecureCart has foundational security tools and policies in place, none of the assessed controls were found to be fully conformant, reflecting significant gaps in governance, enforcement, and operational implementation. A comprehensive presentation of the evidence collected and the detailed analysis of each finding is provided in Section 4.

The most severe findings, requiring immediate attention, relate to three systemic risk areas: (1) access control and identity lifecycle management, where shared accounts and manual offboarding create persistent unauthorized access risks (A.5.16, A.5.18, A.8.2); (2) data protection and cryptography, where customer and payment data flows through uncontrolled channels without masking or encryption (A.5.14, A.8.11, A.8.12, A.8.24); and (3) incident management readiness, where the existing plan is untested and operationally unreliable (A.5.24). These areas represent the highest regulatory and operational exposure for SecureCart and should anchor the remediation roadmap.

Organizational Controls (A.5)

Control	Name	Conformity	Classification
A.5.1	Policies for Information Security	Partially Conformant	Major
A.5.2	Information Security Roles and Responsibilities	Partially Conformant	Major
A.5.4	Management Responsibilities	Partially Conformant	Minor
A.5.7	Threat Intelligence	Nonconformant	Major
A.5.9	Inventory of Assets	Partially Conformant	Major
A.5.10	Acceptable Use of Assets	Nonconformant	Major
A.5.12	Classification of Information	Partially Conformant	Major
A.5.13	Labeling of Information	Nonconformant	Major

Control	Name	Conformity	Classification
A.5.14	Information Transfer	Nonconformant	Critical
A.5.15	Access Control	Partially Conformant	Major
A.5.16	Identity Management	Partially Conformant	Critical
A.5.17	Authentication Information	Partially Conformant	Major
A.5.18	Access Rights	Nonconformant	Critical
A.5.19	Information Security in Supplier Relationships	Nonconformant	Major
A.5.20	Addressing Security in Supplier Agreements	Nonconformant	Major
A.5.21	Managing Information Security in the ICT Supply Chain	Nonconformant	Major
A.5.22	Monitoring of Supplier Services	Nonconformant	Major
A.5.23	Information Security for Cloud Services	Partially Conformant	Major
A.5.24	Incident Management Planning	Partially Conformant	Critical
A.5.25	Assessment of Security Events	Nonconformant	Major
A.5.26	Response to Incidents	Partially Conformant	Major
A.5.27	Learning from Incidents	Nonconformant	Major
A.5.34	Privacy and Protection of PII	Partially Conformant	Critical

Table 1: Organizational Controls — Summary of Findings

People Controls (A.6)

Control	Name	Conformity	Classification
A.6.3	Security Awareness and Training	Partially Conformant	Major
A.6.7	Remote Working	Nonconformant	Major

Table 2: People Controls — Summary of Findings

Technological Controls (A.8)

Control	Name	Conformity	Classification
A.8.1	User Endpoint Devices	Partially Conformant	Major
A.8.2	Privileged Access Rights	Nonconformant	Critical
A.8.3	Information Access Restriction	Partially Conformant	Major
A.8.5	Secure Authentication	Partially Conformant	Critical

Control	Name	Conformity	Classification
A.8.8	Management of Technical Vulnerabilities	Partially Conformant	Major
A.8.11	Data Masking	Nonconformant	Critical
A.8.12	Data Leakage Prevention	Nonconformant	Critical
A.8.13	Information Backup	Nonconformant	Major
A.8.15	Logging	Partially Conformant	Major
A.8.16	Monitoring Activities	Partially Conformant	Major
A.8.24	Use of Cryptography	Nonconformant	Critical

Table 3: Technological Controls — Summary of Findings

4 Detailed Findings

4.1 Organizational Controls

4.1.1 A.5.1 — Policies for Information Security

Conformity: Partially Conformant **Classification:** Major

Description: ISO 27001:2022 requires that information security policies are formally established, approved by management, communicated to all relevant personnel, and reviewed at planned intervals.

Evidence collected:

Pros:

- "States a commitment to confidentiality, integrity, and availability"
- "Annual policy review planned"
- "Policies are distributed via the internal wiki"

Versus:

- "No systematic confirmation that employees read or accept policies"
- "Security awareness training exists, but it is optional"

Gap identified: While a policy exists and is distributed, there is no mechanism to confirm that employees have read or accepted it. The optional nature of security awareness training further weakens enforcement of policy obligations.

Recommendation: Implement a formal policy acknowledgement process requiring all employees to confirm they have read and understood the information security policy. Make security awareness training mandatory and track completion.

4.1.2 A.5.2 — Information Security Roles and Responsibilities

Conformity: Partially Conformant **Classification:** Major

Description: ISO 27001:2022 requires that information security roles and responsibilities are clearly defined, formally assigned, and communicated across the organization.

Evidence collected:

Pros:

- "Security responsibility is assigned to the Head of IT"

Versus:

- No evidence of formal security role definitions in the remaining departments (Operations, Marketing, Customer Support, Finance)

Gap identified: Security responsibility is concentrated in a single role without formal definition or communication of security responsibilities across all departments that handle sensitive data.

Recommendation: Define and formally assign information security responsibilities for all relevant departments. Document these assignments and communicate them to all personnel.

4.1.3 A.5.4 — Management Responsibilities

Conformity: Partially Conformant **Classification:** Minor

Description: ISO 27001:2022 requires that management actively demonstrates commitment to information security by allocating resources, enforcing policies, and integrating security requirements into organizational processes.

Evidence collected:

Pros:

- "The company has committed to achieving ISO27001 certification"
- "Security responsibility is assigned to the Head of IT"

Versus:

- "Security awareness training exists, but it is optional" — management does not ensure enforcement of security obligations

Gap identified: Management commitment is declared but not operationally enforced. The optional nature of security training indicates that management is not actively ensuring compliance with security obligations.

Recommendation: Management should formally enforce security policies, make training mandatory, and integrate security requirements into performance and operational processes across all departments.

4.1.4 A.5.7 — Threat Intelligence

Conformity: Nonconformant **Classification:** Major

Description: ISO 27001:2022 requires that the organization collects, analyses, and acts on threat intelligence relevant to its assets and operational environment.

Evidence collected:

Versus:

- "The company has faced multiple phishing attempts and malware attacks targeting customer and payment data" — despite known attacks, no formal process to collect, analyse, or act on threat intelligence is referenced in the scenario

Gap identified: Despite known attacks, there is no formal process to collect, analyse, or act on threat intelligence. The organization is reactive rather than proactive in addressing threats.

Recommendation: Establish a formal threat intelligence process, including subscription to relevant threat feeds, regular review of emerging threats targeting e-commerce platforms, and integration of intelligence findings into security controls and SIEM tuning.

4.1.5 A.5.9 — Inventory of Information and Other Associated Assets

Conformity: Partially Conformant **Classification:** Major

Description: ISO 27001:2022 requires a complete, accurate, and up-to-date inventory of all information assets, with assigned owners and defined classification levels.

Evidence collected:

Pros:

- "Asset inventory is maintained in spreadsheets"
- The asset management policy defines the following asset categories: servers, databases, cloud services, laptops, and source code repositories, with classification levels of Public, Internal, and Confidential.

Versus:

- "Cloud assets are created dynamically without inventory updates"

Gap identified: The inventory is incomplete because dynamically provisioned cloud assets are not recorded. The use of spreadsheets also limits scalability and accuracy for a cloud-first organization.

Recommendation: Implement an automated asset discovery and inventory tool integrated with the cloud provider. Establish a process to register new assets at provisioning time and review the inventory regularly.

4.1.6 A.5.10 — Acceptable Use of Information and Other Associated Assets

Conformity: Nonconformant **Classification:** Major

Description: ISO 27001:2022 requires that acceptable use rules for information and organizational assets are formally documented and communicated to all employees and contractors.

Evidence collected:

Versus:

- "Bring-Your-Own-Device (BYOD) allowed for some remote developers without formal approval"
- No acceptable use policy for information and assets is referenced in the scenario documentation.

Gap identified: There is no acceptable use policy in place. BYOD usage without formal controls or policy represents a significant risk to the confidentiality and integrity of organizational data.

Recommendation: Develop and implement a formal acceptable use policy covering all information assets, including BYOD devices. Require all employees and contractors to acknowledge and comply with the policy.

4.1.7 A.5.12 — Classification of Information

Conformity: Partially Conformant **Classification:** Major

Description: ISO 27001:2022 requires that information is classified in accordance with defined levels that reflect its sensitivity and criticality, consistently applied across all assets.

Evidence collected:

Pros:

- The asset management policy defines classification levels: Public, Internal, and Confidential.

Versus:

- "No data classification labels applied in practice"
- "No structured process to classify personal vs. sensitive information"

Gap identified: Classification levels are defined in policy but never operationalized. Without applied classification, employees cannot make informed decisions about how to handle different types of information.

Recommendation: Implement a classification procedure that assigns classification levels to all existing and new information assets. Provide training to employees on how to identify and handle information according to its classification.

4.1.8 A.5.13 — Labeling of Information

Conformity: Nonconformant **Classification:** Major

Description: ISO 27001:2022 requires that appropriate classification labels are consistently applied to information assets in accordance with the organization's classification scheme.

Evidence collected:

Versus:

- "No data classification labels applied in practice"

Gap identified: Despite a classification policy existing, no labels are applied to any information asset. This makes it impossible for users to identify the sensitivity of information they are handling.

Recommendation: Define and enforce a labeling procedure for all information assets, including documents, datasets, and system outputs. Implement technical controls to apply labels automatically where possible.

4.1.9 A.5.14 — Information Transfer

Conformity: Nonconformant **Classification:** Critical

Description: ISO 27001:2022 requires that policies and controls are in place to protect information during transfer, both within the organization and externally.

Evidence collected:

Versus:

- "Marketing exports customer datasets locally for analysis"
- "Customer support tickets sometimes include full payment information"

Gap identified: Sensitive customer and payment data is being transferred and stored without adequate controls. Local exports of customer datasets create uncontrolled copies of sensitive data, and payment data exposure in support channels represents a critical risk.

Recommendation: Implement controls to restrict and monitor the export of customer data. Prohibit the inclusion of payment data in support tickets and implement DLP controls to detect and block such transfers. Establish a formal information transfer policy.

4.1.10 A.5.15 — Access Control

Conformity: Partially Conformant **Classification:** Major

Description: ISO 27001:2022 requires that access control policies are formally established, implemented, and reviewed, ensuring access is granted in accordance with business and security requirements.

Evidence collected:

Pros:

- "Role-based access control (RBAC)"

- "Unique usernames for each employee"
- "Access to production systems is limited to the IT team" (policy)

Versus:

- "Shared admin accounts still exist for legacy systems"
- "MFA is enabled only for VPN access, not internal cloud dashboards"
- "Developers frequently access production databases for troubleshooting"

Gap identified: Access control is defined in policy but not consistently enforced. Developers bypass production access restrictions, shared accounts undermine individual accountability, and MFA is not applied to all critical systems.

Recommendation: Enforce RBAC consistently across all systems, eliminate shared accounts, extend MFA to all cloud dashboards and critical systems, and implement technical controls to prevent unauthorized production access.

4.1.11 A.5.16 — Identity Management

Conformity: Partially Conformant **Classification:** Critical

Description: ISO 27001:2022 requires a formal process for managing the full lifecycle of user identities, including timely provisioning and de-provisioning across all systems.

Evidence collected:

Pros:

- "Unique usernames for each employee"

Versus:

- "The HR onboarding/offboarding process relies on manual email requests"
- "Shared admin accounts still exist for legacy systems"
- "Employees sometimes retain access to sensitive systems even after changing roles or leaving the organization"

Gap identified: Identity lifecycle management is manual and unreliable. The dependency on email requests for provisioning and deprovisioning creates delays and gaps that result in unauthorized access being retained.

Recommendation: Implement an automated identity and access management (IAM) solution integrated with HR systems to ensure timely provisioning and deprovisioning. Eliminate shared accounts and conduct regular access reviews.

4.1.12 A.5.17 — Authentication Information

Conformity: Partially Conformant **Classification:** Major

Description: ISO 27001:2022 requires that authentication credentials are securely allocated, managed, and protected, with policies covering complexity, rotation, and revocation.

Evidence collected:

Pros:

- "Passwords change every 90 days"
- "MFA is enabled only for VPN access"

Versus:

- "MFA is enabled only for VPN access, not internal cloud dashboards"
- "Shared admin accounts still exist for legacy systems" — shared credentials prevent individual accountability

Gap identified: While a password rotation policy exists and MFA is partially deployed, coverage is incomplete. Shared credentials in legacy systems further undermine the integrity of authentication controls.

Recommendation: Extend MFA to all systems, enforce individual accounts across all platforms including legacy systems, and review password policies to ensure they meet current security standards.

4.1.13 A.5.18 — Access Rights

Conformity: Nonconformant **Classification:** Critical

Description: ISO 27001:2022 requires that user access rights are reviewed at regular intervals and that excessive or unnecessary rights are revoked promptly, particularly following role changes or terminations.

Evidence collected:

Versus:

- "Employees sometimes retain access to sensitive systems even after changing roles or leaving the organization, increasing the risk of unauthorized access"
- "The HR onboarding/offboarding process relies on manual email requests"
- No formal access rights review or revocation process is described in the scenario.

Gap identified: Access rights are not systematically reviewed or revoked. The manual offboarding process frequently results in retained access, creating a significant risk of unauthorized access by former or reassigned employees.

Recommendation: Implement a formal access rights review process on a regular basis (at minimum quarterly). Automate access revocation upon role change or termination and maintain audit logs of all access changes.

4.1.14 A.5.19 — Information Security in Supplier Relationships

Conformity: Nonconformant **Classification:** Major

Description: ISO 27001:2022 requires that information security requirements are formally identified and agreed upon for all supplier relationships.

Evidence collected:

Versus:

- "No formal supplier risk assessment process"
- "Security requirements are inconsistently included"

Gap identified: There is no systematic approach to managing information security risks in supplier relationships. Security requirements are applied inconsistently, leaving significant gaps in the organization's supply chain security posture.

Recommendation: Develop and implement a formal supplier security management process, including risk assessments for all suppliers, minimum security requirements, and regular reviews of supplier compliance.

4.1.15 A.5.20 — Addressing Information Security Within Supplier Agreements

Conformity: Nonconformant **Classification:** Major

Description: ISO 27001:2022 requires that supplier agreements formally include information security requirements proportionate to the sensitivity of the data and systems involved.

Evidence collected:

Versus:

- "Contracts focus mainly on SLA availability"
- "Security requirements are inconsistently included"

Gap identified: Supplier contracts do not formally address information security obligations. The focus on availability SLAs without security requirements leaves the organization exposed to risks arising from supplier non-compliance.

Recommendation: Update all supplier contracts to include formal information security requirements, covering data protection obligations, incident notification, access controls, and the right to audit.

4.1.16 A.5.21 — Managing Information Security in the ICT Supply Chain

Conformity: Nonconformant **Classification:** Major

Description: ISO 27001:2022 requires that the organization defines and implements processes to manage information security risks associated with the ICT supply chain. This includes ensuring that security requirements flow down to ICT product and service suppliers, that the provenance and integrity of components are verified, and that the organization maintains visibility over the security practices of entities within its ICT supply chain.

Evidence collected:

Versus:

- "Offshore development contractor" engaged without documented security requirements specific to ICT supply chain integrity
- "Security requirements are inconsistently included" in supplier agreements
- "No formal supplier risk assessment process" — no mechanism to assess ICT-specific risks such as malicious code insertion, counterfeit components, or compromised software builds
- "Contracts focus mainly on SLA availability" — no requirements addressing secure development practices, code review obligations, or software composition verification for the offshore contractor

Gap identified: SecureCart relies on an offshore development contractor to contribute to its custom e-commerce platform — a critical ICT supply chain relationship. However, there is no process in place to manage the security risks specific to this relationship. The absence of requirements for secure coding practices, code integrity verification, and supply chain transparency means that malicious or vulnerable code could be introduced into the platform without detection. This gap is distinct from the general supplier management gaps identified in A.5.19 and A.5.20: while those controls address supplier relationships broadly, A.5.21 specifically concerns the integrity and security of ICT products and services embedded in the organization’s systems.

Recommendation: Establish a formal ICT supply chain security programme covering all suppliers that contribute software or infrastructure components to SecureCart’s platform. This should include mandatory secure development lifecycle (SDLC) requirements for the offshore development contractor, software composition analysis (SCA) to identify vulnerable or malicious open-source dependencies, contractual obligations for code integrity assurance (e.g., signed commits, artifact signing), and a process to verify the provenance of ICT components before deployment to production.

4.1.17 A.5.22 — Monitoring, Review, and Change Management of Supplier Services

Conformity: Nonconformant **Classification:** Major

Description: ISO 27001:2022 requires that supplier services are regularly monitored and reviewed, and that security-relevant changes are assessed and controlled.

Evidence collected:

Versus:

- "Vendor security audits are ad hoc"
- "No formal supplier risk assessment process"
- "Contracts focus mainly on SLA availability"
- No mechanism to monitor security performance or assess security-relevant changes by suppliers is described in the scenario.

Gap identified: There is no structured process to monitor or review supplier services from a security perspective. Changes made by third-party providers — including the cloud hosting provider, payment gateway, and offshore development contractor — are not assessed for their security impact. This leaves SecureCart exposed to risks introduced by supplier-side changes without any organizational awareness or control.

Recommendation: Establish a formal supplier monitoring programme including periodic security reviews of all critical suppliers, a process to be notified of and assess security-relevant changes, and regular review of supplier compliance against contractual security obligations.

4.1.18 A.5.23 — Information Security for Use of Cloud Services

Conformity: Partially conformant **Classification:** Major

Description: ISO 27001:2022 requires that information security requirements for cloud services are formally defined, implemented, and monitored, including shared responsibility arrangements.

Evidence collected:

Pros:

- The scenario identifies a cloud hosting provider as part of SecureCart’s infrastructure.
- Centralized SIEM collects logs from cloud systems

Versus:

- “Cloud assets are created dynamically without inventory updates”
- “MFA is enabled only for VPN access, not internal cloud dashboards”
- “Security requirements are inconsistently included” in supplier and cloud provider contracts.
- No shared responsibility model defining SecureCart’s obligations versus those of the cloud provider is described in the scenario.

Gap identified: While cloud services are actively used, there is no formal framework governing their security. The absence of a shared responsibility model, insufficient access controls over cloud dashboards, and untracked dynamic provisioning create significant security gaps in the cloud environment.

Recommendation: Formally document the shared responsibility model with the cloud provider. Define and enforce security requirements for all cloud services, extend MFA to cloud dashboards, and implement cloud security posture management (CSPM) to monitor configuration compliance and detect unauthorized resource provisioning.

4.1.19 A.5.24 — Information Security Incident Management Planning and Preparation

Conformity: Partially conformant **Classification:** Critical

Description: ISO 27001:2022 requires a formally documented and maintained incident management process, including defined roles, escalation paths, communication procedures, and preparedness activities.

Evidence collected:

Pros:

- "Incident Response Plan created 18 months ago" — a formal document exists

Versus:

- "Incident Response Plan ... has not been tested or updated in the last year"
- "No tabletop exercises performed"
- "Roles in incident response are unclear"
- "Forensics capability outsourced but not contractually defined"

Gap identified: Although an incident response plan exists, it is outdated, untested, and operationally ineffective. Unclear role assignments mean that personnel do not know their responsibilities during an incident. The absence of exercises means the plan has never been validated, and the undefined forensics arrangement leaves the organization without a reliable evidence-handling capability.

Recommendation: Update the incident response plan to reflect the current organizational structure and threat landscape. Formally define roles and responsibilities for all involved personnel. Conduct tabletop exercises at least annually. Formalize the forensics outsourcing arrangement through a contractually defined service agreement.

4.1.20 A.5.25 — Assessment and Decision on Information Security Events

Conformity: Nonconformant **Classification:** Major

Description: ISO 27001:2022 requires that information security events are assessed in a timely and consistent manner using defined criteria to determine whether they constitute incidents requiring escalation.

Evidence collected:

Versus:

- "Alerting rules exist, but are not regularly tuned" — no reliable mechanism to distinguish events from incidents
- "Roles in incident response are unclear" — no defined ownership for event triage and assessment

- No event classification criteria or decision thresholds are described in the scenario.

Gap identified: There are no defined criteria or procedures for assessing security events and deciding whether they require escalation to incident status. Without structured triage, events detected by the SIEM may be missed, misclassified, or left unaddressed, increasing the risk of undetected breaches.

Recommendation: Define and document formal event classification criteria, including severity thresholds and escalation triggers. Assign clear ownership for event triage and ensure that all SIEM alerts are reviewed within defined timeframes. Integrate event assessment procedures into the updated incident response plan.

4.1.21 A.5.26 — Response to Information Security Incidents

Conformity: Partially conformant **Classification:** Major

Description: ISO 27001:2022 requires that incidents are responded to through coordinated containment, eradication, and recovery actions, with responsibilities clearly assigned.

Evidence collected:

Pros:

- "Incident Response Plan created 18 months ago" — provides a documented baseline for response actions

Versus:

- "Roles in incident response are unclear" — no clear assignment of containment, eradication, or recovery responsibilities
- "No tabletop exercises performed" — response procedures have never been validated
- "Forensics capability outsourced but not contractually defined" — evidence handling during incidents is unreliable

Gap identified: While a response plan exists on paper, its operational effectiveness is severely limited. Unclear role assignments and lack of exercises mean that when an incident occurs, personnel may not know what actions to take or who is responsible, leading to delayed or disorganized responses.

Recommendation: Revise the incident response plan to clearly assign containment, eradication, and recovery responsibilities to named roles. Conduct regular exercises to validate and improve response procedures. Formalize the forensics arrangement to ensure evidence is handled in a manner that supports legal and regulatory requirements.

4.1.22 A.5.27 — Learning from Information Security Incidents

Conformity: Nonconformant **Classification:** Major

Description: ISO 27001:2022 requires that post-incident reviews are conducted to identify root causes and lessons learned, and that corrective actions are implemented to prevent recurrence.

Evidence collected:

Versus:

- "The company has faced multiple phishing attempts and malware attacks" — no evidence of post-incident reviews following these events
- "Incident Response Plan . . . has not been tested or updated in the last year" — indicates that lessons from past incidents have not been incorporated
- No post-incident review process or corrective action tracking mechanism is described in the scenario.

Gap identified: Despite experiencing real security incidents, there is no evidence that post-incident reviews have been conducted or that corrective actions have been implemented. This prevents the organization from improving its security posture based on operational experience and increases the likelihood of incident recurrence.

Recommendation: Establish a formal post-incident review process to be conducted after every significant security event. Document root cause analysis findings, define corrective actions with assigned owners and deadlines, and track actions to closure. Use findings to update the incident response plan and security controls on a continuous basis.

4.1.23 A.5.34 — Privacy and Protection of PII

Conformity: Partially conformant **Classification:** Critical

Description: ISO 27001:2022 requires that privacy and protection measures for personally identifiable information are formally implemented, including lawful processing, access limitation, retention control, and appropriate safeguards.

Evidence collected:

Pros:

- Privacy and Data Protection Policy states compliance with GDPR-like principles: collection limitation, data minimization, purpose limitation, and right to erasure

Versus:

- "Marketing exports customer datasets locally for analysis" — PII copied to uncontrolled local environments
- "Customer support tickets sometimes include full payment information" — sensitive PII exposed in support channels
- "Data retention rules exist, but are inconsistently applied"
- "No structured process to classify personal vs. sensitive information"

Gap identified: While a privacy policy exists, its practical implementation is severely lacking. PII is handled without adequate controls: it is copied locally by Marketing without oversight, exposed in support channels, and subject to inconsistently applied retention rules. The absence of data classification means that employees cannot distinguish between personal and sensitive data categories, making appropriate handling impossible.

Recommendation: Implement a comprehensive PII handling framework covering classification, access control, and retention enforcement. Prohibit uncontrolled local exports of customer data. Enforce data minimization in support processes to prevent payment data from appearing in tickets. Conduct a data retention audit and enforce defined retention periods across all systems.

4.2 People Controls

4.2.1 A.6.3 — Information Security Awareness, Education, and Training

Conformity: Partially conformant **Classification:** Major

Description: ISO 27001:2022 requires an ongoing information security awareness and training program for all employees and contractors covering their security responsibilities.

Evidence collected:

Pros:

- "Security awareness training exists"

Versus:

- "Security awareness training exists, but it is optional"
- "No systematic confirmation that employees read or accept policies"

- No evidence that training content covers threats such as phishing is provided in the scenario, despite the organization having suffered phishing attacks.

Gap identified: A training programme exists but its voluntary nature means that employees most likely to benefit from it — those handling sensitive data or with privileged access — may never complete it. Without mandatory training and completion tracking, the organization cannot demonstrate that all personnel are aware of their security responsibilities.

Recommendation: Make security awareness training mandatory for all employees and contractors, with role-specific modules for personnel handling sensitive data or operating with elevated privileges. Implement completion tracking and require annual re-certification. Ensure training content covers relevant threats such as phishing, social engineering, and data handling obligations.

4.2.2 A.6.7 — Remote Working

Conformity: Nonconformant **Classification:** Major

Description: ISO 27001:2022 requires formal security policies for remote working, including measures to protect information accessed outside the organization’s premises.

Evidence collected:

Pros:

- "MFA is enabled only for VPN access" — some protection for remote connectivity exists

Versus:

- "Bring-Your-Own-Device (BYOD) allowed for some remote developers without formal approval"
- No formal remote working policy documented
- No evidence of endpoint security requirements for remote devices
- No security baseline controls for BYOD devices are described in the scenario, meaning access to production systems cannot be restricted or verified

Gap identified: There is no formal remote working policy. BYOD usage is permitted without a documented approval process or defined security baseline, meaning that unmanaged personal devices may be used to access sensitive organizational systems and data. This creates significant risk of data exposure, malware introduction, and unauthorized access.

Recommendation: Develop and implement a formal remote working policy covering acceptable device types, minimum security requirements (e.g., encryption, screen lock, up-to-date OS and

antivirus), and the conditions under which remote access is permitted. Establish a formal BYOD programme with a registration and approval process, and enforce endpoint compliance checks before granting access to organizational systems.

4.3 Technological Controls

4.3.1 A.8.1 — User Endpoint Devices

Conformity: Partially conformant **Classification:** Major

Description: ISO 27001:2022 requires that endpoint devices used by users (e.g., laptops, desktops, mobile devices) are protected through appropriate security measures to reduce risks such as unauthorized access, malware infection, or data leakage.

Evidence collected:

Pros:

- Asset policy defines laptops as information assets subject to inventory and patching obligations

Versus:

- "Bring-Your-Own-Device (BYOD) allowed for some remote developers without formal approval" — unmanaged personal devices in use
- No evidence of endpoint security controls such as encryption, mobile device management (MDM), or antivirus enforcement
- No formal BYOD security baseline or compliance verification

Gap identified: While company-owned assets are nominally tracked, BYOD devices used by remote developers operate without any enforced security baseline. The absence of endpoint management controls means that unmanaged devices could introduce malware, store sensitive data without encryption, or provide an undetected attack path into the organization's systems.

Recommendation: Implement an endpoint security policy covering all devices used to access organizational systems, including BYOD. Enforce minimum security requirements such as full-disk encryption, screen lock, up-to-date antivirus, and OS patching. Deploy a mobile device management or unified endpoint management (UEM) solution to enforce compliance and enable remote wipe in the event of device loss or theft.

4.3.2 A.8.2 — Privileged Access Rights

Conformity: Nonconformant **Classification:** Critical

Description: ISO 27001:2022 requires that the allocation and use of privileged access rights is restricted, controlled, and regularly reviewed across all systems.

Evidence collected:

Versus:

- "Shared admin accounts still exist for legacy systems"
- "Developers frequently access production databases for troubleshooting"

Gap identified: Privileged access is not controlled. Shared admin accounts prevent accountability and auditability, and developers have unrestricted access to production databases outside of their defined role.

Recommendation: Implement a Privileged Access Management (PAM) solution. Eliminate shared admin accounts, enforce just-in-time privileged access, and log all privileged activity. Restrict developer access to production through change-controlled procedures.

4.3.3 A.8.3 — Information Access Restriction

Conformity: Partially Conformant **Classification:** Major

Description: ISO 27001:2022 requires that access restrictions ensure users only have access to information and systems required for their specific role.

Evidence collected:

Pros:

- "Role-based access control (RBAC)"
- "Unique usernames for each employee"

Versus:

- "Developers frequently access production databases for troubleshooting" — beyond their defined role
- Shared admin accounts undermine individual access restrictions

Gap identified: Access restriction policies exist but are not enforced. The principle of least privilege is not applied in practice, with developers accessing systems beyond their role requirements.

Recommendation: Enforce least privilege access across all systems. Conduct a role-based access review to align actual access rights with job requirements, and implement technical controls to prevent unauthorized access to production environments.

4.3.4 A.8.5 — Secure Authentication

Conformity: Partially Conformant **Classification:** Critical

Description: ISO 27001:2022 requires that secure authentication mechanisms, including multi-factor authentication, are enforced across all systems and applications.

Evidence collected:

Pros:

- "Passwords change every 90 days"
- "MFA is enabled only for VPN access"

Versus:

- MFA is not extended to internal cloud dashboards or other critical systems.
- "Shared admin accounts still exist for legacy systems" — undermining individual authentication.

Gap identified: MFA is only partially deployed. Critical internal systems, including cloud dashboards, are not protected by MFA, exposing them to credential-based attacks. Shared accounts further undermine authentication integrity.

Recommendation: Enforce MFA across all systems and applications, prioritizing cloud dashboards and production environments. Eliminate shared accounts and enforce individual authentication for all users.

4.3.5 A.8.8 — Management of Technical Vulnerabilities

Conformity: Partially Conformant **Classification:** Major

Description: ISO 27001:2022 requires a formal process to identify, assess, and remediate technical vulnerabilities across all systems in a timely manner.

Evidence collected:

Pros:

- The asset management policy assigns patching obligations to asset owners, indicating awareness of vulnerability management at the policy level.

Versus:

- No patch management or vulnerability scanning process is described in the scenario.

Gap identified: While vulnerability management is acknowledged at the policy level, there is no formal process to identify, scan, or remediate technical vulnerabilities in practice.

Recommendation: Implement a formal vulnerability management program including regular scanning of all systems, a defined remediation timeline based on severity, and patch management procedures.

4.3.6 A.8.11 — Data Masking

Conformity: Nonconformant **Classification:** Critical

Description: ISO 27001:2022 requires that data masking is applied to protect sensitive information, particularly in non-production environments and in operational contexts where full data access is not necessary.

Evidence collected:

Versus:

- "Marketing exports customer datasets locally for analysis" — no data masking controls are referenced in the scenario.

Gap identified: Sensitive personal and payment data is processed and stored without masking, exposing it unnecessarily to personnel who do not require access to the full data.

Recommendation: Implement data masking for all non-production uses of customer data. Apply tokenization or masking to payment data in support systems and marketing exports.

4.3.7 A.8.12 — Data Leakage Prevention

Conformity: Nonconformant **Classification:** Critical

Description: ISO 27001:2022 requires that data leakage prevention measures are in place to detect and prevent unauthorized transmission of sensitive information.

Evidence collected:

Versus:

- "Customer support tickets sometimes include full payment information"
- No data leakage prevention controls are described in the scenario.

Gap identified: There are no technical controls to detect or prevent the leakage of sensitive data, either through support channels or local data exports. This represents a critical gap given the volume of payment and personal data processed.

Recommendation: Deploy a DLP solution to monitor and block unauthorized transmission of sensitive data across email, ticketing systems, and file transfers. Define and enforce data handling rules for all departments.

4.3.8 A.8.13 — Information Backup

Conformity: Nonconformant **Classification:** Major

Description: ISO 27001:2022 requires that backup copies of information, software, and system images are taken and tested regularly in accordance with a defined backup policy.

Evidence collected:

Versus:

- No backup policy or testing procedures are described in the scenario.

Gap identified: While cloud infrastructure may provide inherent backup capabilities, there is no formal policy defining backup scope, frequency, retention, or testing. Without tested backups, the organization cannot confirm its ability to recover from data loss or a ransomware attack.

Recommendation: Define and implement a formal backup policy covering all critical systems and data. Establish regular backup testing procedures and document recovery time and recovery point objectives (RTO/RPO).

4.3.9 A.8.15 — Logging

Conformity: Partially Conformant **Classification:** Major

Description: ISO 27001:2022 requires that event logs are recorded, protected, and retained across all systems in accordance with a defined log retention policy.

Evidence collected:

Pros:

- "Logs collected in a centralized SIEM"

Versus:

- "No log retention policy"
- "Alerting rules exist, but are not regularly tuned"

Gap identified: Log collection is in place but lacks governance. Without a retention policy, logs may be deleted before they are needed for incident investigation or compliance purposes.

Recommendation: Define and implement a formal log retention policy specifying retention periods per log type. Ensure logs are protected against tampering and accessible for incident response and audit purposes.

4.3.10 A.8.16 — Monitoring Activities

Conformity: Partially Conformant **Classification:** Major

Description: ISO 27001:2022 requires that networks and systems are continuously monitored to detect anomalies, unauthorized access, and potential security incidents.

Evidence collected:

Pros:

- A centralized SIEM is in place for monitoring

Versus:

- "Alerting rules exist, but are not regularly tuned"
- No defined ownership for monitoring activities is described in the scenario.

Gap identified: Monitoring infrastructure is in place but lacks operational maturity. Untuned alert rules increase the risk of both missed detections and alert fatigue, reducing the effectiveness of the monitoring capability.

Recommendation: Establish a regular SIEM tuning process, assign clear ownership for monitoring activities, and define escalation procedures for detected anomalies. Review and update detection rules based on emerging threats.

4.3.11 A.8.24 — Use of Cryptography

Conformity: Nonconformant **Classification:** Critical

Description: ISO 27001:2022 requires that cryptographic controls are formally defined and applied to protect sensitive information, both in transit and at rest.

Evidence collected:

Versus:

- No documented cryptographic policy or standards defining which algorithms, key lengths, or protocols are required
- "Marketing exports customer datasets locally for analysis" — no evidence that locally exported data is encrypted at rest
- "Customer support tickets sometimes include full payment information" — payment data transmitted and stored without evidence of adequate cryptographic controls
- No evidence of encryption enforcement for BYOD or remote devices storing organizational data

Gap identified: There is no formal cryptographic policy governing the protection of sensitive data. The absence of defined standards means that encryption may be applied inconsistently or not at all across systems, endpoints, and data transfers. Given that SecureCart processes payment card data and personal information at scale, this represents a critical gap with direct regulatory implications.

Recommendation: Define and implement a formal cryptographic policy specifying approved algorithms, minimum key lengths, and protocols for data in transit (e.g., TLS 1.2 or higher) and at rest (e.g., AES-256). Enforce encryption on all endpoints, including BYOD devices, and on all storage locations handling sensitive or payment data. Establish a key management process covering key generation, distribution, rotation, and revocation.

5 Audit Summary & Analysis

This section provides a comprehensive quantitative and qualitative analysis of the audit findings. Rather than merely enumerating the nonconformities, this analysis seeks to identify the root causes of SecureCart’s security gaps and evaluate their potential impact on the organization’s business objectives, regulatory standing, and customer trust.

5.1 Compliance Distribution and Maturity Assessment

Out of the 36 ISO/IEC 27001:2022 controls assessed across the Organizational, People, and Technological domains, none were found to be fully conformant. As illustrated in Figure 1, the controls are distributed between Partially Conformant (52.78%, 19 controls) and Nonconformant (47.22%, 17 controls).

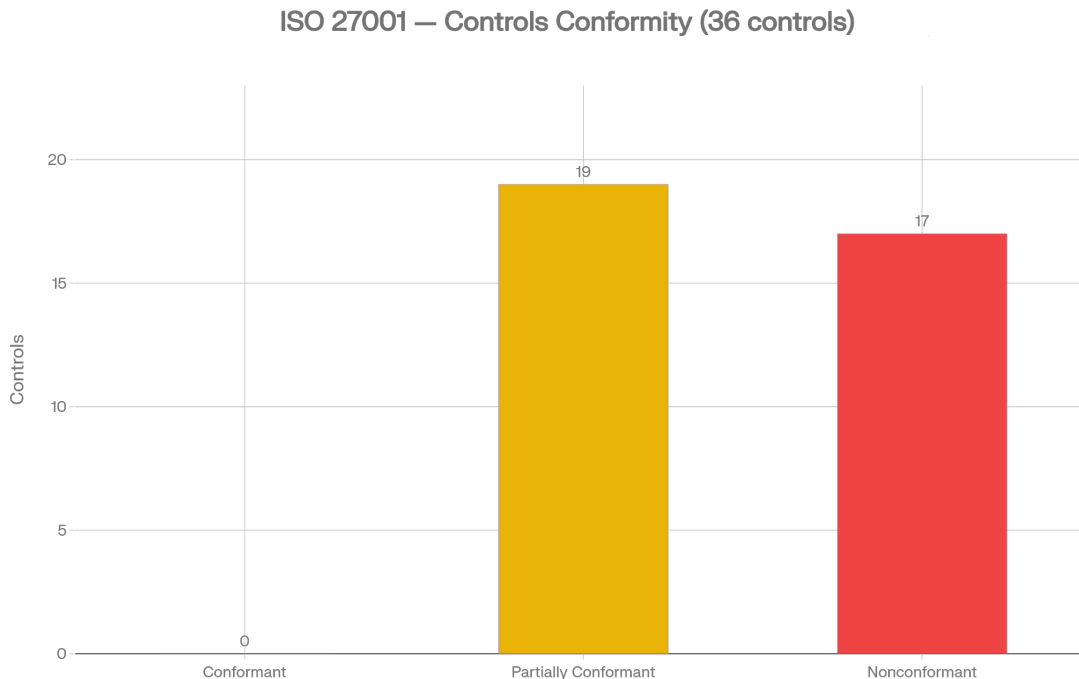


Figure 1: Distribution of ISO 27001 Controls Conformity Status

This 0% full compliance rate is typical for organizations undergoing their first formal security audit after a period of rapid hyper-growth. The high percentage of "Partially Conformant" controls reveals a specific maturity profile: SecureCart possesses the foundational security *tools* and *intentions* (e.g., a centralized SIEM, a VPN, documented policies), but severely lacks the *governance*, *automation*, and *enforcement* required by ISO 27001. The organization is currently operating at an ad-hoc maturity level, where security relies on manual effort (e.g., spreadsheet inventories, email-based HR offboarding) rather than systematic processes.

5.2 Gap Severity and Root Cause Analysis

The severity distribution (Figure 2) highlights the immediate risk posture of the organization. The audit identified 10 Critical gaps, 25 Major gaps, and 1 Minor gap.

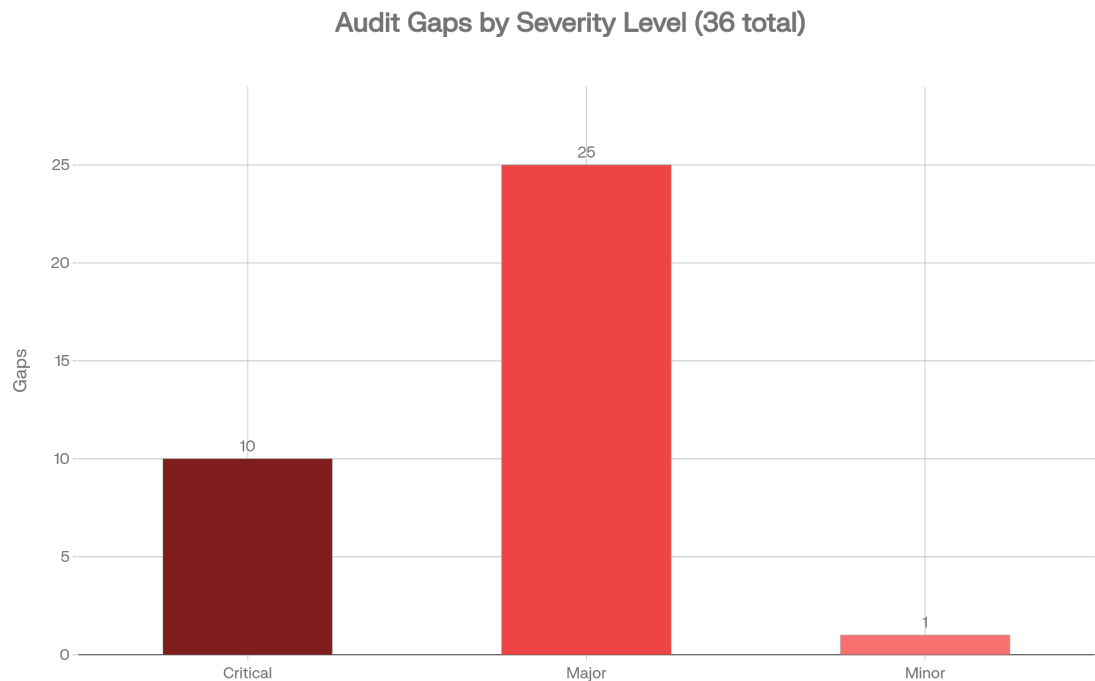


Figure 2: Audit Findings by Severity Level

A deeper root-cause analysis of these findings reveals three systemic vulnerabilities within SecureCart’s operations:

5.2.1 The ”Scale-Up” Access Control Breakdown

A significant portion of the Critical gaps (A.5.18, A.8.2, A.8.5) stems from access management practices that failed to scale with the company’s workforce. The reliance on manual email requests for HR offboarding guarantees that orphaned accounts persist. Furthermore, the existence of shared admin accounts on legacy systems and developers directly accessing production databases for troubleshooting indicates a culture that prioritizes operational speed over security segregation, undermining the principle of least privilege across critical systems.

5.2.2 E-commerce Data Exposure and Regulatory Risk

As an e-commerce platform processing credit card information and PII for over 1 million users, SecureCart faces immense regulatory (GDPR) and industry (PCI-DSS) obligations. However, Critical

gaps in Data Leakage Prevention (A.8.12) and Data Masking (A.8.11) show that sensitive data flows freely across unsecured internal channels. The practices of Marketing exporting customer datasets locally and Customer Support receiving full payment details in plaintext tickets expose the company to massive financial and reputational risks in the event of an endpoint compromise.

5.2.3 The Supply Chain and Cloud Blind Spot

SecureCart relies heavily on a modern, distributed architecture: cloud hosting, third-party payment gateways, and offshore developers. Yet, Major gaps in supplier relationships (A.5.19, A.5.20, A.5.21) reveal a critical blind spot. Contracts focus exclusively on availability SLAs, completely ignoring security requirements, right-to-audit clauses, or secure coding practices for offshore teams. Critically, A.5.21 exposes an even deeper risk: the offshore development contractor contributes code directly to the e-commerce platform with no documented requirements for secure development lifecycle (SDLC) practices, software composition analysis, or code integrity verification — meaning malicious or vulnerable code could be introduced into production without detection. The organization is delegating infrastructure management to the cloud without formalizing a shared responsibility model, creating a false sense of security.

5.3 Conclusion of the Current State

In its current state, SecureCart’s Information Security Management System (ISMS) is fragmented. While the Head of IT has nominal responsibility for security, there is a clear disconnect with other business units (Marketing, HR, Support), which routinely bypass security best practices to execute their daily tasks. To achieve ISO 27001 certification, SecureCart must transition from a reactive, IT-centric security posture to a proactive, organization-wide governance model.

6 Audit Conclusions

6.1 Overall Audit Opinion

Based on the evidence collected and the findings documented in this report, the audit team concludes that SecureCart Inc.'s Information Security Management System (ISMS) **does not currently meet the requirements of ISO/IEC 27001:2022** and is therefore **not recommended for certification** at this stage.

The audit identified a total of 36 nonconformities across the assessed controls: 10 Critical, 25 Major, and 1 Minor. No assessed control was found to be fully conformant. The absence of any conformant control, combined with the breadth and severity of the identified gaps, indicates that the ISMS is not yet systematically implemented, enforced, or evidenced to the degree required by the standard.

6.2 Conditions for Certification

For SecureCart to be recommended for ISO/IEC 27001:2022 certification in a future audit cycle, the following conditions must be met:

- **Closure of all Critical nonconformities**, with objective evidence demonstrating effective implementation and sustained operation of the corrective controls.
- **Substantial closure of Major nonconformities**, with documented corrective actions and verifiable evidence for each finding.
- **Evidence of ISMS operation over time**, including policy acknowledgement records, access review logs, incident records, training completion records, and supplier assessment documentation.
- **A successful Management Review**, demonstrating top management's active oversight of the ISMS performance and risk posture.
- **A completed internal audit** covering the full scope of the Statement of Applicability, conducted by competent and independent personnel, with documented findings and closed corrective actions.

6.3 Follow-Up Audit

A follow-up audit will be conducted once SecureCart has addressed the nonconformities documented in this report. The follow-up assessment will verify the effective closure of findings through objective evidence, including updated documentation, system configurations, process records, and where applicable, re-testing of previously failed controls. Closure of all Critical nonconformities is a prerequisite for any subsequent recommendation for ISO/IEC 27001:2022 certification.

6.4 Closing Statement

This report has been prepared by the audit team in good faith, based solely on the information and evidence made available during the audit engagement. The findings and conclusions presented herein reflect the state of SecureCart Inc.'s ISMS as observed at the time of the audit and do not constitute a guarantee of the absence of additional nonconformities beyond those identified. The audit team encourages SecureCart's management to treat this report as a foundation for structured improvement and remains available to provide clarification on any finding documented herein.